# Enumération de la bases de données :

C'est bien de détecter une SQLi encore faut-il l'exploiter efficacement
ou accéder au contenu de la base de donnée
SQLMap dispose d'un bon nombre de payloads pour effectuer ces tâches.
-- banner : pour récupérer la bannière avec version de la SGBD
-- current-user : pour essayer de récupérer l'utilisateur courant.
-- current-db : pour le nom de la base de données actuelle
-- passwords : récupérer les HashPages de mot de pass
-- is-dba : pour vérifier si notre utilisateur actuelle à des droits DBA (administrateurs)
-- tables -D database_name : énumérations des tables d'une base de donné
-- dump -T table_Name : extraction du contenu de la table spécifié le con
nu de la table est exfiltrer dans un fichier au format CSV
Pour les très grandes DB on peu vouloir limiter l'exfiltration à certaines colon
cela se fait de la manière suivante : --dump -T table -D bata_base -C n
colone1, namecolone2, etc
On peu aussi limiter les lignes en fonction de leurs numéro d'ordre dans la t
avec les options suivante : Ex: --start=2 --stop=123
Si on veux récupérer que certaines lignes en fonction d'une condition (WHE
spécifique on peux le faire de la manière suivante : Ex : --where="name LIKE '
"

On peux aussi faire une "enumeration bourrin" complète de la base de donnée
--dump : collecter tout le contenu de la base de donnée courante
--dump-all : collecter le contenu de TOUTE les bases de données...
--exclude-sysdbs : conseiller surtout en environnement réel cela permet d'e
xclure les bases de données system de la SGBD souvent sans emportance.
--schema : recupère le shéma de la DB cela permet d'avoir une vue d'ensemble
pouvoir mieux cibler les données sensibles
On peux également rechercher toute les colonnes ou table contenant un mot cl
avec le flag suivant --search -T user ou encore --search -C pass
A noter qui SQLMap possède aussi une fonction de craquage des Hash recuperer à l
de d'une wordlist des 1'400 milles entrées les plus standart cette option est activ
par défault avec le --batch sinon le choix nous est proposé...

Pour les applications qui utilisent des jetons anti-csrf, pour valider les
quetes de formulaires, SQLMap peux automatiquement extraire et utilis
de nouveaux jetons --csrf-token="nom_du_jeton"
Si une application utilise une valeur unique dans un paramètre pour cha
requêtes... --randomize=nom_du_parametre
L'option --eval="" permet de donner un mini script python qui s'ex
juste avant chaque requêtes peux être très utile dans certains cas

Pour masquer son adresse IP ou contourner un blocage par IP :
--proxy="urldupproxy" : utiliser un proxy comme un SOCKS4
--check-tor : vérifier que les requêtes passe bien a travers le reseau tor.
--tor : pour router le trafic à travers le reseau tor.

Pour skiper la détection de WAF (Firewall d'application Web) qui est utilisé pa
défault on peux utiliser --skip-waf
Si le user-agent par défault de SQLMap est bloqué on à l'option : --random-ag
A Signaler que de nos jours les parfeu d'application web ne nous laissent quasi
une marge de manoeuvre.
Il y à aussi les tampers (petits scripts d'evasion de WAF diverses : Ex base64-enc
on peu les lister avec --list-tampers et utiliser : --tamper=<script1>,<script2
--chunked : une option puissante d'evasion elle divise le corps de la requete e
morceau "inofensif" pour le WAF mais le serveur reconstruit le payload...